

安全运营最优调度理论的工程实践对话

——用“够用就行”重新解释厂商方案

李龙胜

2026 年 6 月 24 日

奇安信的智能分诊、深信服的威胁定性、腾讯云的 *Multi-Agent*——
这些工程实践，都可以在“够用就行”的理论框架中找到统一解释。
它们不是在“分类”，而是在“逼近台账的 A 值”。
它们不是在“卷降噪率”，而是在“逼近最优分析率 r^* ”。
本文为理论体系补齐了与工业界前沿的对话接口。

摘要

当前国内主流安全厂商在告警降噪领域已积累丰富的工程实践，但缺乏统一的理论框架来解释这些实践为什么有效、何时应该继续优化、何时应该停止。本文将“够用就行”理论与八家厂商的工程方案进行系统对话，从智能分诊、降噪率竞赛、优先级排序、对抗鲁棒性和差异化对接五个维度展开分析。核心结论：厂商的工程实践本质上都是在逼近台账的 A 值和最优分析率 r^* ，而“够用就行”理论为这些实践提供了统一的解释框架和理性的优化终点——边际收益等于边际成本。

目录

1	引言：理论与工程实践的对话需求	1
2	智能分诊的本质：用 AI 逼近台账的 A 值	2
2.1	厂商实践	2
2.2	理论解释	2
2.3	理论能为厂商提供什么	2
3	降噪率竞赛的理性终点：边际收益等于边际成本	2
3.1	厂商实践	2
3.2	理论解释	2
3.3	理论能为厂商提供什么	3

4	优先级排序的统一框架：从多维打分到成本-收益对比	3
4.1	厂商实践	3
4.2	理论解释	3
4.3	理论能为厂商提供什么	3
5	对抗性鲁棒性的缺失与柯克霍夫原则的补位	4
5.1	厂商现状	4
5.2	理论解释	4
5.3	理论能为厂商提供什么	4
6	厂商分类与理论对接的差异化路径	4
6.1	平台型厂商（奇安信、深信服）	4
6.2	Agent 型厂商（腾讯云、绿盟科技）	4
6.3	情报型厂商（微步在线）	4
7	诚实标注	5
8	结语	5

1 引言：理论与工程实践的对话需求

安全运营最优调度理论已经完成了从公设推导、台账量化、贪心择优、柯克霍夫原则到四步调度模型的完整理论构建。同时，通过学术文献综述，理论在对抗性博弈和成本敏感决策两个方向上确立了学术定位。

然而，理论同样需要与当前工业界的工程实践进行对话。国内主流安全厂商——奇安信、深信服、腾讯云、阿里云、微步在线、绿盟科技、360、亚信安全——已经在告警降噪领域积累了丰富的工程经验，推出了各具特色的技术方案。这些工程实践，与理论之间存在着大量尚未被系统阐述的对应关系。

本文旨在搭建这座桥梁。用“够用就行”理论，重新解释厂商的工程实践——他们做得对的地方为什么对，他们还没做到的地方在哪里，以及理论能为他们的下一步优化提供什么指导。

2 智能分诊的本质：用 AI 逼近台账的 A 值

2.1 厂商实践

奇安信的“智能分诊”由专家经验模型和 AI 模型共同驱动，对告警自动过滤、识别、排序、合并和处置。深信服的“威胁定性”将告警一键定性为业务误触、普通病毒、自动化攻击或定向攻击。腾讯云的“Multi-Agent 研判”从七个维度展开调查，最终输出结论加证据链加处置建议。

2.2 理论解释

所有这些操作，本质上都在做同一件事：用 AI 模型去估计一条告警的漏报损失（A 值）。厂商用各种复杂的模型——大模型、机器学习、威胁情报——给告警打分。这个“分”，在理论

里对应的就是台账里的 A 值。

厂商的分诊模型训练得越准，就越接近台账里那本经过精心标定的 A 值表。区别在于，厂商用一个黑盒的 AI 模型去逼近 A 值，理论用一个透明的台账去记录 A 值。两者目标完全一致，只是手段不同。

2.3 理论能为厂商提供什么

- **解释为什么 AI 分诊有效：**因为它本质上是在逼近最优分析率 r^* 的计算，这一计算的数学基础已由贪心择优定理严格证明。
- **解释为什么 AI 分诊有时会失效：**因为 AI 模型本身也会过拟合，也需要定期重新校准——这和台账需要定期全量回溯是同一个问题。
- **提供轻量级替代方案：**对于没有足够数据训练 AI 模型的企业，可以直接用台账手工标定 A 值，用贪心择优做调度，效果同样可控。

3 降噪率竞赛的理性终点：边际收益等于边际成本

3.1 厂商实践

深信服降噪率 99%，奇安信降噪率 98%，腾讯云降噪率 97.7%。所有厂商都在卷降噪率，将其作为核心竞争指标。

3.2 理论解释

从“够用就行”理论来看，降噪率不是越高越好。当降噪率已经很高时，继续提升的边际成本——需要更复杂的模型、更多的算力、更贵的工程师——可能已经超过了它能避免的边际安全损失。

最优降噪率，不是预算可以支撑的最高降噪率，而是让安全总成本最低的那个降噪率。

3.3 理论能为厂商提供什么

- **提供降噪率竞赛的理性终点：**当降噪的边际成本等于它所能避免的边际安全损失时，就不应该继续优化了。
- **引导厂商从“卷降噪率”转向“卷总成本最优化”：**一个新的产品竞争维度——不是谁的降噪率更高，而是谁帮客户在安全投入上达到了最优性价比。
- **解释为什么不同客户的“最优降噪率”不同：**因为不同客户的成本函数和威胁环境不同。一个金融客户和一个制造企业，对漏报的容忍度完全不同——他们的最优降噪率自然不同。

4 优先级排序的统一框架：从多维打分到成本-收益对比

4.1 厂商实践

当前各厂商的优先级排序依赖多维特征——攻击类型、资产重要性、威胁情报、AI 置信度。它们把这些特征输入一个复杂的模型，输出一个优先级分数。

4.2 理论解释

从理论来看，所有这些多维特征，最终都可以也应该被统一到同一个判据下：分析这条告警的成本（ κ ），和漏掉这条告警的损失（ αA ），哪个更大？

- 攻击类型 → 影响漏报损失 A ；
- 资产重要性 → 影响漏报损失 A ；
- 威胁情报 → 影响漏报损失 A （已知恶意 IP 的攻击成功率更高）；
- AI 置信度 → 影响分析成本 κ （高置信度可更快处理）。

所有特征，最终都在影响两个核心变量： A 和 κ 。而最优决策只取决于这两个变量的比较结果：若 $\alpha A > \kappa$ ，告警值得分析；否则不值得。

4.3 理论能为厂商提供什么

- **降低跨环境部署成本：**厂商不需要在每个客户环境中从头训练一个新的优先级模型。只需要帮助客户标定台账里的 A 值和 κ 值，然后套用贪心择优的调度算法即可。
- **提升跨环境泛化能力：**台账参数是透明的、可审计的、可由客户自行维护的，不依赖厂商的专有训练数据。
- **增强可解释性和可审计性：**优先级排序不再是黑盒 AI 的输出，而是可追溯的成本-收益计算。客户可以质疑、修正台账参数，而不是被动接受 AI 的判断。

5 对抗性鲁棒性的缺失与柯克霍夫原则的补位

5.1 厂商现状

学术文献综述已指出，当前所有厂商的 AI 分诊系统都缺乏对抗鲁棒性——攻击方会主动适应防御策略，用对抗样本欺骗 AI 模型。厂商的方案在这个维度上几乎是空白。

5.2 理论解释

厂商的 AI 模型是一个静态的分类器——训练好了就部署，攻击方可以通过反复试探找到模型的盲区。而理论从设计之初就内建了对抗性防御：

- **参数周期性扰动：**每次演练后对台账参数施加微小扰动，使攻击方在上个周期积累的探测知识强制过期；

- **伪造响应：**以一定概率伪造分析或忽略结果，让攻击方面临欠定推断困境。

这两个机制不需要对抗训练，不需要重新训练模型，只需要对台账参数施加微小扰动，在裁定响应时注入随机噪声。

5.3 理论能为厂商提供什么

- **提供轻量级的对抗性防御方案：**可立即部署，不依赖对抗样本数据，有效性有严格的信息论下界支撑。
- **提升 AI 分诊系统的安全鲁棒性：**将厂商的静态 AI 模型升级为动态对抗系统，让攻击方始终面临不确定的决策环境。

6 厂商分类与理论对接的差异化路径

不同的厂商有不同的技术路线和产品形态，理论与它们的对接路径也应差异化。

6.1 平台型厂商（奇安信、深信服）

最适合直接嵌入 OSM-Sec 模型——用台账系统替代或补充现有的优先级排序逻辑，用贪心择优替代复杂的 AI 分诊调度。

6.2 Agent 型厂商（腾讯云、绿盟科技）

适合将台账 A 值作为 Agent 决策的经济判据，让人机协同的推迟决策有明确的成本-收益支撑——当 AI 判断不确定性导致的期望损失超过人工介入的成本时，自动推迟给人类分析师。

6.3 情报型厂商（微步在线）

适合将威胁情报直接映射为 A 值的修正系数——已知恶意 IP 的 A 值自动上调，已知扫描器的 A 值自动下调。将情报从“辅助判断”升级为“经济参数”。

7 诚实标注

命题	状态	层级
智能分诊的本质分析	厂商分诊操作的目标是逼近 A 值和 r^* ，逻辑完备	II（理论解释已建立）
降噪率竞赛的理性终点	最优降噪率由边际收益等于边际成本定义，判据已给出	II（需各厂商内部成本数据验证）
优先级排序统一框架	多维特征可归约至 A 值和 κ 的对比，归约逻辑清晰	II（归约的正确性已论证）

对抗鲁棒性的补位方案	柯克霍夫原则为厂商提供轻量级防御，机制已完备	II（需在真实 AI 分诊系统中验证）
厂商差异化对接路径	平台型、Agent 型、情报型的对接方向已明确	III（具体集成方案需与厂商合作验证）

8 结语

安全运营最优调度理论不再是纸上谈兵。它为当前主流安全厂商的工程实践提供了一个统一的解释框架——智能分诊是在逼近台账的 A 值，降噪率竞赛是在逼近最优分析率 r^* ，优先级排序是在逼近成本-收益对比的数学判据。

更重要的是，它为这些实践指明了下一步的优化方向：不是继续卷降噪率，而是找到那个理性的终点——边际收益等于边际成本。不是继续堆 AI 模型，而是内建对抗性防御，让攻击方始终面临不确定的决策环境。

理论体系的完整性，在此获得了学术研究与工程实践的双重支撑。

文档信息：

- 作者：李龙胜
- 版本：第一版（工程实践对话归档）
- 许可：CC BY 4.0
- 前置依赖：四卷体系、安全厂商调查报告、学术文献个人梳理、学术定位与对话文档